

《软件过程改进方案设计文档》

项目名称：社区慢病随访管理系统

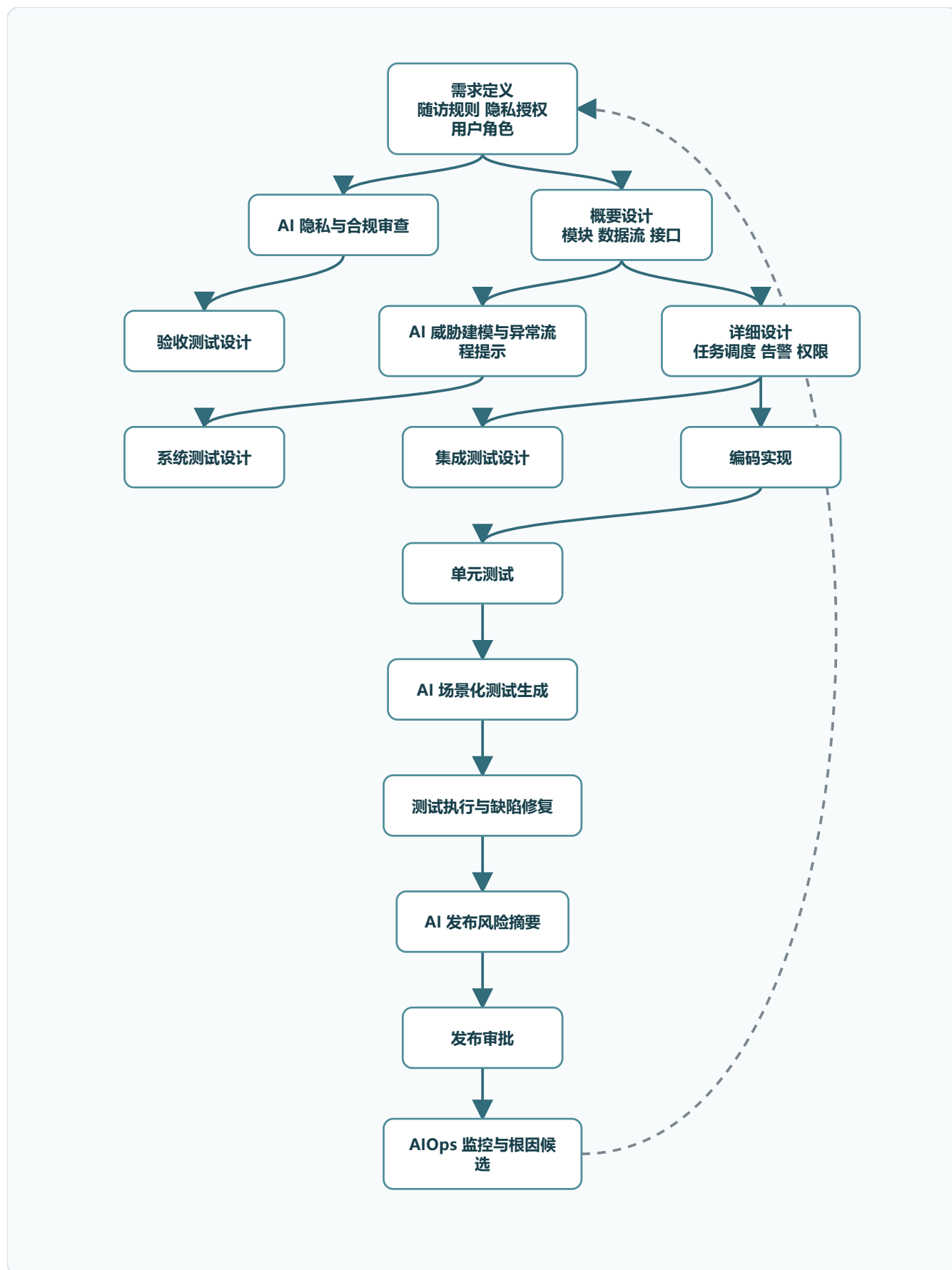
改进目标：在合规约束下的 V 模型基础上，引入 AI 辅助审查、测试生成、发布评估和运维分析能力，形成适合医疗健康类系统的智能化软件过程。

一、改进思路

慢病随访系统的过程改进不能简单照搬互联网应用的高频试错模式。系统处理患者健康数据，且随访提醒、异常指标上报、医生回访等功能会影响实际健康管理。因此，本方案以 V 模型的可追溯性为主线，把 AI 放入“生成候选、发现遗漏、辅助审查、聚类分析”的位置，而不让 AI 做自动医疗判断。

改进目标包括：提升隐私需求和合规条款覆盖；将临床规则更稳定地转化为测试场景；降低发布评审中信息汇总成本；缩短告警根因初判时间；形成 AI 输出审计机制。

二、改进后的过程框架



该流程保留 V 模型“左侧定义、右侧验证”的结构，并在需求、设计、测试、发布、运维五个节点加入 AI 辅助活动。AI 节点的输出不是最终结论，而是进入人工审查的材料。

三、角色调整

角色	职责
产品负责人	管理需求基线，确认随访业务范围和迭代优先级
医生代表	校准临床规则，确认异常指标、随访频率和提醒文案
隐私合规审查员	审查授权、最小必要、审计日志、数据保留和导出限制
临床知识校准员	将医生表述转换成软件规则，审核 AI 对临床术语的理解
架构师	负责模块划分、数据流、权限边界和任务调度设计
AI 测试分析师	生成 BDD 测试、边界场景和异常流程用例
AIOps 工程师	使用日志聚类、异常检测和 AI 摘要辅助故障定位
发布经理	汇总发布风险，组织上线审批和回滚演练

与方案A不同，本方案新增“临床知识校准员”和“隐私合规审查员”，体现医疗健康项目对领域准确性和数据保护的更高要求。

四、工具链选型

改进环节	工具或框架	核心功能	集成方式	预期效率提升
隐私需求审查	LLM + 隐私检查清单	检查授权、审计、保留、导出、删除需求遗漏	需求基线冻结前运行，输出审查问题清单	需求遗漏发现率提升 30%
威胁建模	LLM + STRIDE 模板 + Mermaid	生成数据流风险和威胁候选	设计评审前生成威胁表，由架构师确认	威胁建模准备时间减少 40%
测试生成	Codex/ChatGPT + BDD 模板	从随访规则生成 Given-When-Then 用例	测试负责人筛选后进入测试管理表	异常场景用例增加 50%
自动化脚本	GitHub Copilot + pytest/Playwright	生成单元测试和端到端脚本初稿	开发与测试在 PR 中审查脚本	脚本编写时间减少 30%
发布评估	LLM 发布摘要模板	汇总变更、缺陷、覆盖率、回滚步骤	发布评审会前生成风险摘要	评审准备时间减少 35%
运维分析	Isolation Forest/日志聚类 + LLM 摘要	异常指标检测、日志聚类、根因候选	监控系统导出脱敏数据后分析	故障初判时间减少 30%

五、AI 输出质量标准

AI 隐私审查输出必须列明依据的需求编号、风险类型、建议补充条款和人工确认结果。没有对应需求编号的问题只能作为建议，不能直接改变需求基线。

AI 威胁建模输出必须包含资产、入口、威胁、影响、已有控制和改进建议。涉及医疗判断的内容必须由医生代表确认，AI 不能决定医学阈值。

AI 测试输出必须使用 Given-When-Then 或测试表格式，明确前置条件、输入、操作、预期结果、优先级和映射需求编号。测试负责人必须删除无法执行、重复或超出范围的用例。

AI 发布摘要必须列出数据迁移、权限变更、接口变更、未关闭缺陷、回滚步骤和是否影响患者通知。发布经理对风险级别负责，AI 不具备发布批准权。

六、风险评估与应对

风险	表现	应对策略
隐私泄露	将真实患者姓名、手机号、健康指标输入公共模型	强制脱敏；使用合成数据；敏感字段进入禁止输入清单
临床误解	AI 错误解释医学术语或阈值	医生代表和临床知识校准员双重审核
测试误导	AI 生成看似完整但无法执行的用例	测试负责人筛选；用例必须映射需求编号
合规遗漏	AI 未覆盖特定监管要求	使用人工合规清单作为主控，AI 只做辅助
自动化依赖	团队过度相信 AI 风险评分	发布审批仍由发布经理、测试负责人和合规负责人签字
告警误判	AIOps 把相关性误认为因果	根因候选必须通过日志、指标和代码变更交叉验证

七、度量指标

指标	定义	目标
隐私需求补充率	AI 审查后新增隐私条款数 / 原隐私条款数	20%-40%
临床规则澄清数	AI 或人工发现的需医生确认问题数	每迭代不少于 3 条
AI 测试有效率	人工采纳的 AI 测试用例数 / AI 生成用例数	大于 65%
异常场景覆盖率	异常用例数 / 总用例数	大于 45%
发布摘要准确率	发布后复盘确认摘要覆盖关键风险数 / 实际关键风险数	大于 85%
告警初判时间	从告警出现到形成候选根因的时间	减少 30%

八、落地计划

第 1 周建立隐私需求审查清单、临床术语表和 AI 输出记录模板。第 2 周在“高血压随访提醒”需求上试用 AI 隐私审查和威胁建模。第 3 周进行 AI 测试生成原型验证，并选择 10 条用例转为自动化脚本。第 4 周在一次模拟发布中试用 AI 发布风险摘要和 AI Ops 日志聚类，形成过程改进报告。

本方案的落地重点是“受控使用 AI”。医疗健康软件过程必须避免 AI 直接替代医生判断、合规判断或发布审批。通过职责分离、输出审计、人工签收和度量管理，AI 可以在不削弱安全边界的前提下提高过程效率和

质量。